Authorization

Hostel Management System (HMS) — Software Requirements Specification

Purpose

Specify how the HMS decides whether an authenticated user may access a feature or perform an operation. Authorization is separate from authentication: a valid login does not automatically grant permission to every function.

Core principles

- Use role-based access control (RBAC) with permissions assigned to roles and roles assigned to user accounts.
- Apply least privilege and deny access by default when no explicit permission is present.
- Enforce authorization on the server/service layer for every protected operation. Hiding a button or page in the interface is not a security control.
- Check access to individual records as well as features; users must not access another student's private records merely by changing an identifier.

Typical roles and responsibilities

- Student: view and maintain permitted profile details, submit hostel applications, track own application, view own allotment and fee information, submit complaints, and manage permitted visitor requests.
- Hostel administrator/warden: review applications, manage hostel/room/bed availability, process allotments and check-in/check-out, manage complaints and visitors, and publish notices within assigned hostel scope.
- Finance staff: view and update fee/payment records within the finance workflow; access to unrelated profile or security administration should not be granted by default.
- System administrator: manage user accounts, roles, system configuration, and authorized operational reports. Administrative access should be limited to designated personnel.
- These are baseline role descriptions; the project team must map them to the actual roles and permissions configured in the application.

Authorization checks

- Verify the user's authenticated identity, active account status, required permission, and record/hostel scope before performing an operation.
- For student-owned resources, compare the requested record's owner/student identifier with the authenticated user's identity.
- For hostel-scoped staff, verify that the target hostel is within the staff member's assigned scope.
- Re-check permissions for sensitive actions such as approving applications, changing allotments, recording payments, changing roles, and exporting personal data.

Denied requests

- Reject unauthorized operations without changing data.
- Return a consistent access-denied response without revealing whether protected records exist or exposing private details.

- Record security-relevant permission denials in the audit trail, including actor, attempted action, target where safe, and timestamp.

Role and permission administration

- Only designated administrators may assign or revoke roles.
- Validate role changes, record them in the audit log, and require re-authentication or additional confirmation for high-impact changes where supported.
- When a role is revoked or an account is disabled, the change must take effect promptly for subsequent requests and active sessions according to session-management rules.

Acceptance criteria

- Unauthenticated users cannot access protected HMS functions.
- A student can access only their own restricted student information and permitted workflows.
- Staff can perform only operations allowed by their role and assigned scope.
- Direct API/service requests are protected even if the user bypasses the interface.
- Denied requests do not modify system data and are handled consistently.

Document note: This document defines project-level requirements for the HMS utility. Confirm implementation-specific settings (such as role names, file limits, retention periods, and timeout values) against the approved project configuration before production deployment.